ITA14 – ETHICAL HACKING

ASSIGNMENT 1 – CO1

Design and Develop a Complete Ethical-Hacking Engagement Framework for a University

Complete Model Answers • Tasks 1–11 • Tables • Workflows • Reusable Documents

Student Name(s): _Mahima Prabhakaran_

Register Number(s): ___192521280____

Department / Section: ______Dept IT_____

Date: _01/11/2007_

Assignment Overview

Course Code: ITA14 | Course Name: Ethical Hacking | Course Outcome: CO1

This assignment designs an integrated governance framework for a university security-assessment programme. The framework covers authorization, scope and Rules of Engagement (RoE), legal compliance, threat modelling, ethical conduct, isolated-lab testing, responsible disclosure, reusable documents, integration, scalability and adaptation.

Scenario basis: approximately 20 systems and 50 staff initially, covering the student portal, learning-management system (LMS), university email and campus network segment. The design is intended to scale to the whole university and support external assessors.

Important scope boundary: the assignment is a design and documentation exercise. No live exploitation of production systems is performed. Hands-on testing is confined to an isolated lab with authorized targets.

Integrated Framework Blueprint

```
Department request
    ↓
Written authorization and Engagement ID
    ↓
Scope + Rules of Engagement (RoE)
    ↓
Legal / privacy compliance review
    ↓
Threat model and ethical-conduct checks
    ↓
Isolated-lab assessment
    ↓
Structured finding report
    ↓
Coordinated responsible disclosure
    ↓
Remediation verification and engagement closure

Governance layer: approvals, audit logs, asset inventory, evidence retention and review.
```

The governance layer records each decision and ensures that authorization, legal compliance and university policy are checked before an assessment proceeds.

TASK 1 – Formulate the Enquiry and Framework Blueprint (4 Marks)

1.1 Engagement-governance requirements

Requirement area	Proposed requirement / design decision
Systems in scope	Approximately 20 systems initially: student portal, LMS, university email service and the authorized campus-network segment. Each asset is listed by unique asset ID.
Stakeholders	University management/CISO, department heads, system owners, internal testers, external assessors, Data-Protection Officer (DPO), legal team and students/staff as data subjects.
Expected activities	Reconnaissance, authorized scanning, enumeration, controlled testing in an isolated lab, evidence recording, finding classification, remediation guidance and responsible disclosure.
Constraints	Written authorization is mandatory; testing windows are agreed with system owners; personal data must be protected; production exploitation is excluded; records must be auditable.
Scalability	The same approval, scope, legal, reporting and audit process must support growth to the whole university and onboarding of third-party assessors.

1.2 Requirements-to-governance mapping

Scenario requirement	Framework component	How it is addressed
Prevent unauthorized testing	Authorization workflow	Signed approval, unique Engagement ID and

		approval log before any activity.
Prevent unclear scope	Asset inventory and RoE	Explicit in-scope/out-of-scope asset tags and testing windows.
Avoid legal exposure	Legal-compliance mapping	IT Act, data-protection review and DPO approval where personal data is involved.
Model likely attackers	Threat model	Classifies actors by authorization, intent, capability and affiliation.
Prevent harm to live systems	Isolated lab	Kali Linux and authorized targets on a host-only network.
Control vulnerability communication	Disclosure layer	Private reporting, remediation window, escalation and disclosure decision log.

1.3 Enquiry questions

1. Who is authorized to approve a security assessment, and how is the written authorization recorded and verified?
2. Which university systems are in scope and which systems, networks or third-party services are excluded?
3. Which legal and privacy requirements apply when assessment activity involves systems containing personal data?
4. How are discovered vulnerabilities classified, reported, tracked and disclosed, and within what timeline?
5. Under what conditions may internal staff and external assessors conduct an assessment?

1.4 Design / acceptance criteria

- C1 – Every engagement must have verifiable written authorization before any assessment activity.
- C2 – Scope must be explicit, asset-tagged and checkable so out-of-scope requests can be rejected.
- C3 – Every identified legal requirement must be linked to a concrete framework control.
- C4 – No harmful testing is performed on live production systems; hands-on testing is confined to an isolated lab.
- C5 – Responsible disclosure must use a defined report format and remediation timeline.
- C6 – The framework must scale to university-wide assessments and external assessors while retaining auditable records.

Rationale: these criteria directly address the scenario's principal risks—unauthorized access, unclear scope, personal-data exposure, system damage and uncoordinated disclosure.

TASK 2 – Design a Hacker Threat Model and Classification (4 Marks)

2.1 Hacker classification and threat-model mapping

Hacker type	Motivation	Typical capability	Likely university targets
White-hat	Improve security with authorization.	High; disciplined and scope-controlled.	In-scope systems under an approved engagement.
Black-hat	Financial gain, theft or damage.	High; malicious and unauthorized.	Student records, email accounts and credentials.
Grey-hat	Curiosity; acts without clear authorization, often without malicious intent.	Medium to high.	Public portals and exposed services.
Script kiddie	Thrill, recognition or experimentation with little technical skill.	Low; relies on ready-made tools and scripts.	Easy-to-find exposed systems.
Hacktivist	Political or social message.	Medium; may deface or disrupt public-facing services.	Public university website and communication channels.
Insider	Grievance, personal gain or misuse of trusted access.	Medium; legitimate access can be abused.	Internal applications, HR and finance data.
State-sponsored	Espionage or strategic intelligence gathering.	Very high; stealthy, persistent and well-resourced.	Research data and sensitive institutional records.

2.2 Classification criteria

Each actor is classified using four attributes:

- Authorization: authorized or unauthorized.
- Intent: benign, curiosity-driven or malicious.
- Skill: low, medium or high.

- Affiliation: external, internal or nation-state sponsored.

2.3 Borderline actor and alternative classifications

Scenario: a student discovers a weakness in the university portal without permission and reports it to the university.

Alternative	Reasoning	Decision
Script kiddie	Could apply if the student simply ran a ready-made tool without understanding the result.	Rejected as the primary classification because it describes skill and method, not the authorization/intent combination.
Grey-hat	The student acted without authorization but reports the issue and has no stated malicious intent.	Chosen. Lack of authorization combined with non-malicious intent best fits the grey-hat classification.

If the student demanded payment or used the weakness to steal information, the classification could shift toward black-hat behaviour. The university must still treat the original activity as unauthorized, even if the student reports the flaw.

TASK 3 – Create an Ethics and Code-of-Conduct Module (4 Marks)

3.1 Ethical principles

- Written authorization: no activity begins without a valid signed approval.
- Agreed scope: testers operate only on approved assets, methods and time windows.
- Confidentiality: information discovered during the engagement is protected and shared only with authorized recipients.
- Integrity of evidence: logs, screenshots and findings are preserved accurately and are not altered or fabricated.
- Avoiding harm: intrusive or disruptive actions are prohibited unless separately authorized and safely contained.
- Honest reporting: findings, limitations, false positives and unresolved risks are reported accurately.
- Least intrusion and data minimisation: collect only the minimum evidence needed and do not copy personal data unnecessarily.

3.2 Preventive rules and checks

6. Authorization check: if the Engagement ID and signed approval are missing or invalid, block the activity.
7. Scope check: verify the target asset against the approved inventory before each assessment action.
8. Activity logging: record tester, timestamp, target, tool/action, result and evidence reference.
9. Dual control: require a second authorized reviewer for sensitive or high-impact steps.
10. Stop-and-report: stop testing and notify the governance lead if personal data or an out-of-scope asset is encountered.
11. Evidence handling: store evidence in an access-controlled location and follow the retention schedule.

3.3 Scenario test cases

Action / scenario	Classification	Code-of-conduct response
Testing an in-scope system with written authorization.	Acceptable	Proceed within the approved window and log the activity.
Discovering that an out-of-scope system is reachable.	Borderline situation	Do not test it. Stop and report it to governance for a formal scope decision.
Using discovered credentials to access another system or copying personal data.	Unacceptable	Prohibit the action, halt the engagement, escalate the incident and preserve relevant evidence without further access.

3.4 How the module preserves trust

The module makes tester behaviour predictable and accountable. Written permission establishes authority; scope checks prevent unauthorized expansion; logging supports audit; confidentiality and data minimisation protect individuals; and honest reporting ensures that the university receives reliable results. These controls protect both the university and the assessment team.

TASK 4 – Construct a Legal-Compliance Mapping (4 Marks)

4.1 IT Act 2000 and CFAA comparison

Offence / obligation	Information Technology Act, 2000 (India)	CFAA (United States) equivalent	Penalty / consequence (as summarized in assignment source)
Unauthorized access / damage	Section 43	18 U.S.C. §1030(a)(2)	Compensation; civil or criminal consequences may apply.
Hacking / dishonest access	Section 66	18 U.S.C. §1030(a)(4)	Source model answer indicates up to 3 years / ₹5 lakh.
Identity theft / personation	Sections 66C / 66D	18 U.S.C. §1028 / §1030	Source model answer indicates up to 3 years / fine.
Breach of confidentiality / privacy	Sections 72 / 72A	No direct one-to-one equivalent listed in the source table.	Source model answer indicates up to 2–3 years / fine.
Protection of sensitive personal data	Section 43A; DPDP Act 2023	No direct equivalent listed in the source table.	Compensation / penalties.

4.2 Legal requirements linked to framework controls

Legal requirement	Framework control
Sections 43 / 66 – unauthorized access or damage	Mandatory written authorization, asset-level scope and RoE enforcement; no Engagement ID means no testing.
Section 43A, Sections 72 / 72A and DPDP Act – personal data	Data-handling policy, data minimisation, no exfiltration, secure evidence storage and DPO approval.
Confidentiality and disclosure obligations	Responsible-disclosure process; findings are reported only to the authorized owner and approved recipients.

4.3 Legal requirements when personal data is involved

When systems hold personal data, the assignment's model answer identifies Sections 43A, 72 and 72A and the DPDP Act 2023 in addition to Sections 43 and 66. The engagement must therefore include DPO approval, explicit data-handling rules, minimum evidence collection, secure storage and restricted disclosure. Personal data creates both unauthorized-access and data-protection risks, so the stricter applicable controls must govern the assessment.

TASK 5 – Create a Scope and Rules-of-Engagement Document (4 Marks)

5.1 Scope and Rules of Engagement (RoE)

RoE field	Definition
Engagement identity	Unique Engagement ID, requesting department, assessment lead and approval date.
In-scope assets	Student portal, LMS, university email service and authorized campus-network segment, each listed by asset ID.
Out-of-scope assets	Production databases holding live personal data unless separately authorized; third-party hosted services; and every asset not explicitly tagged in scope.
Testing window	Off-peak hours agreed in advance with system owners.
Permitted techniques	Reconnaissance, scanning and enumeration within approved scope; hands-on exploitation only in the isolated lab.
Prohibited techniques	Denial-of-service, unapproved social engineering of staff, data exfiltration and any testing of out-of-scope assets.
Escalation	Named system-owner contact, governance lead, emergency-stop procedure and incident-handling route.
Evidence handling	Record actions and findings; store evidence securely; avoid collecting personal data; follow retention rules.

5.2 Authorization recording and verification

12. Create a request with a unique Engagement ID.

13. Obtain signatures from the system owner and authorized university approver (CISO/governance authority).
14. Obtain legal/DPO review where personal data or legal risk is involved.
15. Store the signed authorization and approved scope in the engagement register.
16. Before testing, verify the ID, signatures, target list, techniques and dates. No valid ID means no test.

5.3 Out-of-scope detection

Maintain an asset inventory with explicit IN_SCOPE or OUT_OF_SCOPE tags. Every requested target is checked against this inventory before activity. A target not tagged IN_SCOPE is rejected by default and referred to governance for approval; it is never added informally during testing.

5.4 Derived pre-engagement checklist

- Written authorization signed and verified.
- Engagement ID issued and recorded.
- Scope confirmed against the asset inventory.
- Testing window agreed with system owners.
- Named contacts and escalation path confirmed.
- Isolated lab configured and verified.
- Legal and data-protection review completed.
- Data-handling and evidence-retention rules agreed.

TASK 6 – Build an Authorization and Disclosure Layer (5 Marks)

6.1 Authorization workflow

```
Department request → Governance review → Legal / DPO review (if required)
    → System-owner + CISO approval → Signed authorization recorded
    → Engagement ID issued → Scope / RoE verified → Assessment begins
    → Findings reviewed → Engagement closed
```

The workflow ensures that the request, approval, written sign-off, scope and dates are recorded before assessment activity begins.

6.2 Coordinated responsible-disclosure process

17. Prepare a finding report containing title, affected asset, severity (CVSS), evidence, impact and remediation recommendations.
18. Send the report privately to the authorized system owner and designated security contact.
19. Record the report date, recipient, severity, remediation deadline and status.
20. Use a default remediation window of 90 days, with 30 days for critical findings, as specified in the assignment model answer.
21. Track remediation and communicate status updates. Verify the fix before closure.
22. Escalate overdue findings to governance. Disclosure proceeds only after the remediation window or owner agreement, subject to legal and privacy restrictions.

6.3 Disclosure approaches compared

Approach	Description	Advantages / risks
Coordinated disclosure	Finding is privately reported and the owner receives a remediation window before disclosure.	Chosen default; gives the owner time to fix the issue and reduces user exposure.
Full disclosure	Finding is published immediately.	Can create pressure to fix, but may expose users while the vulnerability remains unresolved.
Bug bounty	Testing and reporting are pre-authorized under a published programme and defined scope; rewards may be offered.	Provides clear rules and incentives, but applies only to the programme's approved scope and conditions.

6.4 Logging and decision operations

Operation	Purpose
logApproval(engagement_id, approver, timestamp, decision)	Records who approved or rejected an engagement and when.
updateStatus(finding_id, status, timestamp, note)	Tracks finding lifecycle: submitted, acknowledged, in remediation, fixed, verified or closed.
canDisclose(finding)	Checks remediation window, owner agreement, legal restrictions, personal-

	data exposure and governance approval before disclosure.

6.5 Coordinated versus full disclosure decision rules

- Default to coordinated disclosure and private reporting.
- Consider limited public disclosure only if the remediation window has lapsed, risk remains high and no personal data is exposed, subject to governance and legal review.
- Findings involving personal data remain private and are escalated through the appropriate authorized channels, including CERT-In as indicated in the assignment model answer.
- Only disclose findings relating to assets and activities covered by the engagement authorization and RoE.

Interaction: the disclosure layer reads the legal-compliance result (personal data means private handling) and the RoE (only in-scope findings are reported to authorized owners). It therefore cannot operate independently of authorization and legal review.

TASK 7 – Design an Isolated Ethical-Hacking Lab (5 Marks)

7.1 Lab architecture

Use a Kali Linux attacker virtual machine and one or more authorized target virtual machines, such as DVWA or Metasploitable, connected through a host-only virtual network. The example network is 192.168.56.0/24 and has no default gateway or route to the internet or production network.

Component	Role	Example address / configuration
Kali Linux VM	Attacker / tester workstation	192.168.56.10
Target VM (DVWA)	Authorized vulnerable target	192.168.56.20
Host-only virtual switch	Isolated internal network connecting the VMs	192.168.56.0/24; no gateway

7.2 Connectivity and recording operations

Operation 1 – Verify connectivity from Kali to the authorized target:

```
ip a
ping -c 4 192.168.56.20
ip route
```

Expected result: the target responds on the host-only network, and the routing table shows no route that would allow the lab target traffic to reach the internet or production network.

Operation 2 – Record the lab configuration:

```
mkdir -p ~/ethical-hacking-lab/evidence
ip a > ~/ethical-hacking-lab/evidence/lab-ip-config.txt
ip route > ~/ethical-hacking-lab/evidence/lab-routes.txt
nmap -sn 192.168.56.0/24 -oN ~/ethical-hacking-lab/evidence/lab-discovery.txt
```

The Nmap discovery command must be used only on the isolated lab subnet. Store the date, VM names, network mode and configuration screenshots with the evidence.

7.3 Host-only versus NAT comparison

Aspect	Host-only (chosen)	NAT
Internet access	No direct internet access; isolated internal network.	Internet access may be available through the host.
Risk of traffic leakage	Very low when configured without a gateway or bridging.	Higher because traffic can leave through NAT.
Suitability	Safer for contained assessment exercises.	Convenient for updates/downloads but less isolated.

Justification: host-only networking is selected because the assignment requires testing to remain authorized and contained. Only the lab VMs are reachable on the isolated network, reducing the risk of accidental contact with production or external systems.

TASK 8 – Develop a Reusable Document Library (4 Marks)

8.1 Reusable engagement documents

Document	Required fields / content	Purpose
1. Authorization Form	Engagement ID, requester, department, assets, scope, dates, approver names/signatures and legal/DPO review.	Provides verifiable permission to conduct the assessment.
2. Scope / RoE Form	In-scope and out-of-scope assets, testing windows, permitted/prohibited techniques, contacts and escalation path.	Defines the boundaries and operational rules.
3. Finding Report	Finding ID, title, asset, severity/CVSS, description, evidence reference, impact, remediation, owner, status and dates.	Creates a consistent vulnerability record.
4. Disclosure Record	Finding ID, report date, recipient, remediation window, status updates, owner agreement and closure date.	Tracks coordinated disclosure and remediation.
5. Pre-engagement Checklist	Authorization, Engagement ID, scope, window, contacts, lab readiness, legal review and data-handling confirmation.	Confirms readiness before testing.

8.2 Structured output and integration

The Finding Report produces a structured record that can be consumed by the disclosure layer and used in scalability reporting.

```
finding_id: F-001
engagement_id: EH-2026-001
asset_id: PORTAL-01
severity: High (CVSS score to be assessed)
evidence_reference: evidence/F-001.txt
status: Reported
remediation_owner: Student Portal System Owner
reported_date: YYYY-MM-DD
```

The disclosure component reads finding_id, asset_id, severity, status and reported date to create a disclosure record and calculate the remediation deadline. Task 10 can count findings by severity and time to closure.

8.3 Document validation test entries

Input / test case	Category	Expected result
Authorization form contains all mandatory fields and valid signatures.	Valid	Accepted; Engagement ID issued and recorded.
Authorization form is complete except for the approver signature.	Boundary	Flagged as incomplete; assessment cannot begin until signature is obtained.
Request is submitted without an authorization form.	Invalid	Rejected automatically; no testing permitted.

TASK 9 – Integrate, Test and Refine the Framework (4 Marks)

9.1 Integration of components

```
Authorization → Scope / RoE → Legal compliance → Threat model
    → Isolated-lab assessment → Finding Report
    → Coordinated disclosure → Remediation verification → Closure

Reusable forms support each stage; governance records decisions and evidence.
```

9.2 Authorized-assessment walkthrough

23. A department requests a security assessment of the student portal.
24. The governance team checks the request, obtains system-owner and CISO approval, records the signed authorization and issues an Engagement ID.
25. The RoE confirms the student portal asset ID, permitted techniques, excluded systems, and testing window.
26. The legal review identifies that the portal may contain personal data; DPO approval and strict evidence-handling rules are applied.
27. The approved assessment activities are demonstrated in the isolated lab using a representative target; no live production exploitation is performed.

28. A hypothetical SQL-injection finding is documented in the structured Finding Report with evidence of reference, severity and remediation recommendation.
29. The finding is privately reported to the authorized owner under the coordinated-disclosure process with the specified remediation window.
30. The owner reports remediation; the assessment team verifies the fix in the lab or through approved evidence, updates the status and closes the engagement.

9.3 Systematic test cases

Test case	Expected framework behaviour
Missing authorization	Engagement is rejected before any activity.
Out-of-scope request	The asset-tag check detects the target and rejects the request.
Personal-data legal conflict with no DPO approval	Activity is blocked until the required DPO approval, and data-handling controls are in place.
Disclosure delayed beyond the remediation window	Governance escalation and review are triggered; public disclosure is not automatic.

9.4 Problems identified and refinement

Initial problem	Refinement	Expected improvement
Out-of-scope detection depended on manual checking.	Add mandatory asset tags and a scope to check before each action.	Out-of-scope targets are rejected consistently.
The disclosure deadline was ambiguous.	Define 90 days as the standard window and 30 days for critical findings, with dates logged.	Deadlines and escalation have become measurable.
Approval evidence could be difficult to trace.	Use a unique Engagement ID and approval register.	Every engagement has an auditable authorization record.

TASK 10 – Create a Scalability and Governance Evaluation (4 Marks)

10.1 Programme scenarios

Scenario	Systems	Testers	Description
Small programme	5 systems	2 internal testers	One department conducts a limited assessment.
Large programme	Approximately 200 systems	20 internal + 10 external testers	Whole university programme with external assessors.

10.2 Process measures

Process	Small programme	Large programme
Approval turnaround	Approximately 4 hours	Approximately 36 hours
Scope coverage	100%	82%
Disclosure workflow steps	5	9

These values reproduce the illustrative comparison in the assignment model-answer section. They should be labelled as example evaluation figures unless the group has independently measured and recorded them.

10.3 Structured visualization

Measure	Small programme	Large programme
Approval turnaround	4 hours | [redacted]	36 hours | [redacted]
Scope coverage	100% | [redacted]	82% | [redacted]
Disclosure steps	5 | [redacted]	9 | [redacted]

10.4 Interpretation and governance refinement

As the programme grows, approval turnaround increases from approximately 4 to 36 hours, scope coverage decreases from 100% to 82%, and the disclosure workflow grows from 5 to 9 steps. This indicates that manual governance does not scale efficiently without additional coordination.

- Introduce delegated approval for predefined low-risk assessments while retaining senior approval for sensitive systems.
- Use parallel legal, DPO and system-owner reviews where possible.
- Standardize external assessment onboarding, confidentiality agreements and access requirements.
- Use risk-based scheduling so critical systems receive priority, and scope coverage improves.
- Automate status tracking and reminders for approvals, remediation deadlines, and disclosure.

The refinement is based on the observed increase in approval time and workflow complexity and the reduction in scope coverage.

TASK 11 – Defend the Framework Under a Changed Requirement (4 Marks)

11.1 Changed requirement

The university now requires continuous assessments, third-party assessors, stricter data-protection controls and a shorter disclosure timeline, while keeping the framework easy to govern and extend.

11.2 Retain, modify, replace and redesign

Action	Component	Revised decision
Retain	Authorization workflow, RoE and isolated lab.	These remain essential controls for permission, scope, and safe hands-on testing.
Modify	Disclosure timeline and legal mapping.	Change remediation window to 30 days, or 7 days for critical findings, as proposed in the assignment model answer; include DPDP Act 2023 duties and stronger data handling.
Modify	External assessor controls.	Require vetting, signed NDA, least-privilege access and audit logging.
Replace	Manual approval for logging.	Use a workflow/ticketing system to improve auditability and status tracking.
Redesign	One-off assessment process.	Adopt a continuous-assessment pipeline with scheduled scope reviews, recurring approvals and ongoing remediation tracking.

11.3 New component: External-Assessor Governance Module

The module applies the same governance expectations to external testers as to internal testers.

- Verify assessor identity, organization, competence and references before onboarding.
- Obtain a signed non-disclosure agreement (NDA) and contractual authorization.
- Grant least-privilege access only to approved assets and for the approved period.
- Provide the assessor with the current RoE, escalation of contacts and data-handling requirements.
- Log assessor actions, evidence access, findings and engagement status.
- Revoke access to engagement closure and retain the required audit records.

Integration: the module connects to the authorization workflow and RoE. External assessors cannot begin until vetting; NDA, scope and written approval are complete.

11.4 Evidence-based defense

- The Task 9 walkthrough demonstrates the complete sequence from request to remediation and closure.
- The Task 10 evaluation identifies approval delays and reduced coverage at scale, supporting delegated approval, parallel review and standardized onboarding.
- The Task 4 legal mapping connects unauthorized access and personal data risks to written authorization, DPO review and data-handling controls.

- The Task 6 disclosure layer provides a tracked remediation process that can be shortened for the revised requirement.

11.5 Trade-offs, limitations and future improvements

Trade-off / limitation	Impact	Future improvement
Shorter remediation window	Can place pressure on system owners and remediation teams, especially for complex findings.	Prioritize by severity, assign remediation owners early and escalate critical findings.
External assessors and continuous testing	Increase coordination, monitoring, onboarding and audit overhead.	Automate onboarding, approvals, evidence tracking and status reporting.
Automated scope and workflow checks	Can reject legitimate changes if the asset inventory is outdated.	Require periodic asset-owner review and a controlled emergency scope-change process.
Isolated lab limitations	A lab may not perfectly reproduce production architecture or configuration.	Use representative configurations and validate remediation through approved non-disruptive checks.

Final defense: the revised framework retains the essential authorization, scope and isolation controls while introducing continuous workflow management, stronger external-assessor governance, stricter data handling, and shorter disclosure deadlines. It is more scalable and auditable, although it requires additional coordination and automation.